

LAB GUIDELINES

Lab 23 — OS and Application Hardening

Maps to CompTIA Server+ objective **3.5 — Given a scenario, apply server hardening methods** (OS hardening: disable unused services, close unneeded ports, install only required software, apply driver updates, apply OS updates, firewall configuration; application hardening: install latest patches, disable unneeded services/roles/features; host security: antivirus, anti-malware, HIDS/HIPS; hardware hardening: disable unneeded hardware, disable unneeded physical ports/devices/functions, set BIOS password, set boot order; patching: testing, deployment, change management).

Run all commands on <https://killercoda.com/playgrounds/scenario/ubuntu>

Required software (free, apt): lynis, apparmor-utils, debsums, aide, chkrootkit, unattended-upgrades

```
apt update && apt install -y lynis apparmor-utils debsums aide chkrootkit unattended-upgrades
```

Step 1 — Baseline scan with Lynis

```
lynis audit system --quick 2>&1 | tail -60
cat /var/log/lynis.log | grep "Hardening index" | tail -1
```

Note the **Hardening index** (0–100). Re-run after each step to watch it climb.

Step 2 — Disable unused services

```
systemctl list-unit-files --type=service --state=enabled
# Examples of services to consider disabling on a pure server build:
for s in cups bluetooth avahi-daemon ModemManager; do
    systemctl disable --now "$s" 2>/dev/null && echo "disabled $s"
done
```

Decision rule: if no role requires it (Lab 10), disable it.

Step 3 — Close unneeded ports

This is the firewall lab (Lab 9) applied to a hardening checklist:

```
ufw default deny incoming
ufw allow 22/tcp
ufw --force enable
ss -tulnp
```

Cross-check listening sockets against the **role inventory** from Lab 10. If a port is listening that no role needs, kill the service.

Step 4 — Install only required software (minimisation)

```
apt list --installed 2>/dev/null | wc -l          # count packages
# Examples of removals on a server image:
apt purge -y telnet ftp rsh-client 2>/dev/null
apt autoremove -y
```

Smaller install footprint = smaller patch surface = fewer CVEs.

Step 5 — Apply OS updates (and the patching workflow)

Server+ 3.5 explicitly says **patching: testing, deployment, change management**. The pipeline:

```
Vendor advisory → test in staging (snapshot first, Lab 15) →
change ticket (Lab 17) → maintenance window →
apply in production (cluster-aware, Lab 14) → verify → close ticket
```

Apply security updates on this host:

```
unattended-upgrade --dry-run -d 2>&1 | tail -30
dpkg-reconfigure -p low unattended-upgrades
```

Step 6 — Driver / firmware updates

See Lab 5. The hardening tie-in: firmware advisories often fix the same CVE classes (Spectre, BMC auth bypass) — patch the silicon, not just the OS.

Step 7 — Application hardening (web role example)

```
apt install nginx
# nginx hardening lines
cat > /etc/nginx/conf.d/hardening.conf <<'EOF'
server_tokens off;
add_header X-Frame-Options DENY;
add_header X-Content-Type-Options nosniff;
add_header Referrer-Policy "no-referrer-when-downgrade";
client_max_body_size 10m;
EOF
nginx -t 2>/dev/null && systemctl reload nginx 2>/dev/null
```

For each running role (Lab 10), apply the equivalent vendor hardening guide.

Step 8 — Host security: HIDS, anti-malware, file integrity

```
# AIDE — host-based intrusion detection via file integrity
aideinit -y -f 2>&1 | tail
ls -lh /var/lib/aide/aide.db.new
mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db # baseline
aide --check 2>&1 | head # should report no changes immediately after baseline

# chkrootkit — anti-rootkit scan
chkrootkit | head -20
```

Linux antivirus (ClamAV) sits in the same category — `apt install clamav clamav-daemon`. HIPS examples = fail2ban, auditd rules from Lab 22.

Step 9 — Mandatory access control (AppArmor)

```
aa-status | head
# Confine a service:
aa-enforce /etc/apparmor.d/usr.sbin.nginx 2>/dev/null
```

Hardening goes beyond Discretionary AC (file mode bits) to MAC (AppArmor / SELinux) — the app is restricted even if a flaw lets it escape its perms.

Step 10 — Hardware hardening checklist

Action	Why
BIOS/UEFI supervisor password	Stop boot-order tampering
Set boot order: internal disk only	Block USB / PXE boot of rogue OS
Disable unused USB ports (BIOS)	Block rogue keyboards / mass storage
Disable Wi-Fi / Bluetooth radios	Reduce radio attack surface
Disable serial / console redirect	Block local console attacks (unless OOB needs it)
Disable PXE / WoL if unused	Block remote pre-boot exploitation

Step 11 — Verify package integrity

```
debsums -c 2>/dev/null | head # files whose checksums don't match the package
```

Anything reported = either an intentional admin change (/etc/...) or compromise. Investigate.

Step 12 — Re-scan with Lynis

```
lynis audit system --quick 2>&1 | grep -E "Hardening index|warning|suggestion" | tail -20
```

Compare the score to step 1.

Free online tools

- **Lynis** — <https://cisofy.com/lynis/>
- **CIS Benchmarks (free PDFs)** — <https://www.cisecurity.org/cis-benchmarks>
- **DISA STIGs** — <https://public.cyber.mil/stigs/>
- **Microsoft Security Compliance Toolkit** — <https://learn.microsoft.com/en-us/windows/security/>

What you learned

- The Lynis-driven hardening loop: scan → fix → re-scan.
- Service minimisation + port reduction + package minimisation.
- Patching workflow with test → change → deploy → verify guardrails.
- App hardening for nginx as the pattern for every other role.
- HIDS/HIPS (AIDE, chkrootkit, AppArmor) and where antivirus fits.
- The full hardware hardening checklist with BIOS, boot order, and unused interfaces.